LENTERA TEKNOLOGI — CYBER SECURITY ASSESSMENT SERVICE

BIMS (Budget Information Management System) / Rekapitulasi Budget FR - Estate

INTERNAL WEB PENETRATION TESTING REPORT — 18 OKTOBER 2026

Target System	Rekapitulasi Budget FR - Estate (BIMS) — https://rekapbudget-estate.first-resources.com / 10.110.1.9:1627
DNS / Routing	CNAME lkt-infra.first-resources.com → A 10.100.2.64 (Reverse Proxy)
Assessment Scope	Internal Non-Destructive Linear Web Pentest (OWASP Top 10 Alur Linear 1 Putaran)
Attacker / Audit Node	Internal Workstation Node (Linux Security Subsystem / RFC1918 Scope)
Access Level Tested	Unauthenticated Access & Controlled Dummy Credential Authentication Probe
Classification	**CONFIDENTIAL — INTERNAL ENTERPRISE SECURITY ASSESSMENT**

1. EXECUTIVE SUMMARY / RINGKASAN EKSEKUTIF

English

On 18 October 2026, a focused, non-destructive internal web penetration test was conducted against the **BIMS (Budget Information Management System) / Rekapitulasi Budget FR - Estate** application. Assessment targeted both the public HTTPS hostname (https://rekapbudget-estate.first-resources.com resolving to 10.100.2.64) and the direct internal instance (http://10.110.1.9:1627).

Testing operated under a linear, single-pass OWASP Top 10 methodology designed to avoid system loops, deep recursion, or service denial. The principal high-risk finding is **F-01: Plaintext HTTP Transport on Internal Login Endpoint (Port 1627)**. Server 10.110.1.9:1627 serves an unencrypted HTTP/1.0 interface with an active login form (POST /masuk), exposing credentials and session tokens to internal network eavesdropping and MitM interception.

Two configuration anomalies were identified: **F-02: Permissive CSP (unsafe-inline)** and **F-03: Redundant Security Headers**. Perimeter defenses on HTTPS demonstrated valid wildcard Sectigo TLS certificates, HSTS, and 401 dummy auth rejection.

Overall Assessment: Evidence supports **1 High-Risk finding** and **2 Configuration Weaknesses**. Post-login cookie flags and IDOR remain unverified due to single-pass constraints.

Bahasa Indonesia

Pada 18 Oktober 2026 dilakukan pengujian penetrasi web internal non-destruktif terhadap sistem **BIMS (Budget Information Management System) / Rekapitulasi Budget FR - Estate**. Pengujian mencakup hostname publik (https://rekapbudget-estate.first-resources.com ter-resolve ke 10.100.2.64) dan instans internal langsung (http://10.110.1.9:1627).

Pengujian menerapkan alur linear satu putaran bebas macet tanpa brute-force atau crawling rekursif. Temuan utama berisiko tinggi adalah **F-01: Transport Plaintext HTTP pada Endpoint Login Internal (Port 1627)**. Host 10.110.1.9:1627 menjalankan layanan HTTP/1.0 tanpa enkripsi (Server: RBFR) yang menyajikan form login (POST /masuk), membuka celah penyadapan kredensial dan sesi di jaringan lokal.

Ditemukan pula dua kelemahan konfigurasi: **F-02: CSP Permisif (unsafe-inline)** dan **F-03: Duplikasi Header Keamanan**. Sisi perimeter HTTPS terverifikasi kuat dengan sertifikat wildcard Sectigo valid, HSTS aktif, serta penolakan login dummy 401.

Kesimpulan Umum: Hasil mendukung **1 Temuan High** dan **2 Kelemahan Konfigurasi**. Atribut cookie sesi dan IDOR ditandai belum teruji akibat limitasi iterasi 1 putaran.

2. TARGET SYSTEM & ASSESSMENT PARAMETERS

English	Bahasa Indonesia
Target 1 (Public Hostname): https://rekapbudget-estate.first-resources.com • DNS Resolution: CNAME lkt-infra.first-resources.com → A 10.100.2.64 • Transport / Web Stack: Nginx Reverse Proxy, HTTP/2 over TLS 1.3/1.2 • Certificate: *.first-resources.com (Sectigo Public Server Authentication CA DV R36) • Validity Period: 2026-06-29 to 2027-01-13 **Target 2 (Internal Direct Service):** http://10.110.1.9:1627 • Network Type: Direct RFC1918 IPv4 Private Address (No PTR/DNS) • Web Stack: HTTP/1.0 Plaintext (Server banner: RBFR) • Application Title: Rekapitulasi Budget FR - Estate (Identical BIMS application) **Engagement Boundary:** Isolated evaluation strictly for the BIMS system scope.	**Target 1 (Hostname Publik):** https://rekapbudget-estate.first-resources.com • Resolusi DNS: CNAME lkt-infra.first-resources.com → A 10.100.2.64 • Transport / Stack: Nginx Reverse Proxy, HTTP/2 melalui TLS 1.3/1.2 • Sertifikat: *.first-resources.com (Sectigo Public Server Authentication CA DV R36) • Masa Berlaku: 2026-06-29 hingga 2027-01-13 **Target 2 (Layanan Internal Langsung):** http://10.110.1.9:1627 • Tipe Jaringan: Alamat Privat IPv4 RFC1918 Langsung (Tanpa PTR/DNS) • Stack Web: HTTP/1.0 Plaintext (Banner server: RBFR) • Judul Aplikasi: Rekapitulasi Budget FR - Estate (Aplikasi BIMS identik) **Batasan Engagement:** Evaluasi terisolasi khusus untuk ruang lingkup sistem BIMS.

3. TESTING METHODOLOGY / METODOLOGI

English	Bahasa Indonesia
1. Passive Reconnaissance: DNS resolution, HTTP-to-HTTPS redirect validation, TLS chain verification, and metadata inspection (/robots.txt, /.well-known/security.txt). **2. Targeted TCP Enumeration:** Rapid single-pass scan via Nmap (-sT -sV -sC -T4 --top-ports 1000 -p1627) against host 10.110.1.9 without UDP flooding or disruptive probes. **3. OWASP Web Analysis:** Non-destructive audit of login endpoint (/masuk), transport security verification, safe dummy credential probing, security header analysis (CSP, HSTS, X-Frame-Options), and cookie inspection. **4. Evidence Classification:** Strict segregation of confirmed exploitable risks vs configuration anomalies vs untested limits.	**1. Reconnaissance Pasif:** Resolusi DNS, validasi redirect HTTP-ke-HTTPS, verifikasi rantai TLS, dan pemeriksaan metadata (/robots.txt, /.well-known/security.txt). **2. Enumerasi TCP Terarah:** Pemindaian satu putaran cepat via Nmap (-sT -sV -sC -T4 --top-ports 1000 -p1627) pada host 10.110.1.9 tanpa UDP scan maupun probe agresif. **3. Analisis Web OWASP:** Audit non-destruktif endpoint login (/masuk), verifikasi keamanan transport, pengujian aman kredensial dummy, inspeksi security headers (CSP, HSTS, X-Frame-Options), dan inspeksi cookie. **4. Klasifikasi Bukti:** Pemisahan ketat antara risiko nyata terverifikasi, anomali konfigurasi, dan batasan belum teruji.

4. RISK MATRIX & FINDINGS OVERVIEW / MATRIKS RISIKO & TEMUAN

Finding ID	Security Issue / Isu Keamanan	Severity	Status / Verification Note
F-01	**Plaintext HTTP Transport on Internal Login Endpoint** *Transport HTTP Plaintext pada Endpoint Login (10.110.1.9:1627)*	**HIGH**	Verified Vulnerability (CWE-319) *Terverifikasi Nyata*
F-02	**Permissive Content Security Policy with unsafe-inline** *Kebijakan CSP Permisif Mengizinkan unsafe-inline*	**MEDIUM**	Configuration Weakness (CWE-1021/79) *Kelemahan Konfigurasi*
F-03	**Redundant & Conflicting Security Headers from Proxy Layer** *Duplikasi dan Konflik Header Keamanan Akibat Layering Proxy*	**LOW**	Configuration Inconsistency (CWE-16) *Inkonsistensi Konfigurasi*
O-01	**Web Server & Backend Tech Stack Banner Disclosure** *Pengungkapan Banner Layanan Server (nginx, Server: RBFR)*	**INFO**	Operational Hygiene Observation *Observasi Higiene Operasional*
O-02	**Metadata Path Redirect & TLS Validation Anomalies** *Anomali Redirect Metadata & Error Validasi TLS (curl 60 / 35)*	**INFO**	Network Telemetry Recording *Catatan Telemetri Jaringan*

5. DETAILED FINDINGS BREAKDOWN / RINCIAN TEMUAN

F-01: Plaintext HTTP Transport on Internal Login Endpoint (Port 1627)

English

Risk Rating: HIGH | **CWE:** CWE-319 | **Status:** Confirmed Verified

Impact:
The application at http://10.110.1.9:1627 runs an unencrypted HTTP/1.0 service serving an active login form (POST /masuk). Because traffic lacks Transport Layer Security (TLS), user/admin credentials and session cookies can be intercepted via ARP spoofing, promiscuous monitoring, or MitM attacks within the internal network.

Detailed Narrative:
Nmap scan revealed TCP port 1627 is open (Server: RBFR). Initial HTTPS probes failed with curl: (35) wrong version number. HTTP/1.0 GET returned a 3,995-byte HTML payload with login form (username, password). A safe dummy credential probe produced HTTP 401 Unauthorized, proving the auth gateway is live.

Recommended Remediation:
1. Rebind BIMS service to 127.0.0.1:1627 and enforce access through an HTTPS reverse proxy.
2. Block direct cross-VLAN inbound access to port 1627 using host-level firewall rules.
3. Force immediate HTTP 301 redirection to HTTPS if port 1627 remains temporarily active.
4. Rotate all user credentials previously entered via this endpoint.

Bahasa Indonesia

Risk Rating: HIGH | **CWE:** CWE-319 | **Status:** Terverifikasi Nyata

Dampak:
Layanan pada http://10.110.1.9:1627 beroperasi pada HTTP/1.0 tanpa enkripsi dan menyajikan form login aktif (POST /masuk). Karena tidak ada proteksi TLS, kredensial pengguna/admin dan cookie sesi berisiko disadap melalui network sniffing, ARP poisoning, atau serangan MitM pada jaringan lokal RFC1918.

Deskripsi Rinci:
Scan Nmap menemukan port TCP 1627 terbuka (Server: RBFR). Probe HTTPS gagal dengan curl: (35) wrong version number. Permintaan HTTP/1.0 GET menghasilkan respons 3.995 byte memuat form login (username, password). Uji kirim kredensial dummy menghasilkan HTTP 401 Unauthorized, membuktikan endpoint autentikasi aktif.

Rekomendasi Perbaikan:
1. Batasi binding BIMS hanya ke 127.0.0.1:1627 dan wajibkan akses via reverse proxy HTTPS.
2. Blokir akses langsung antar-VLAN menuju port 1627 dengan firewall host (iptables).
3. Terapkan redirect 301 otomatis ke HTTPS bila port 1627 tetap dibuka sementara.
4. Rotasi kata sandi seluruh staf yang pernah login melalui endpoint IP plaintext tersebut.

```
$ nmap -sT -sV -sC -T4 --top-ports 1000 -p1627 10.110.1.9
PORT     STATE SERVICE VERSION
1627/tcp open  http    RBFR custom HTTP server (HTTP/1.0)
|_http-server-header: RBFR
|_http-title: Rekapitulasi Budget FR - Estate

$ curl -i http://10.110.1.9:1627/masuk
HTTP/1.0 200 OK
Server: RBFR



$ curl -k https://10.110.1.9:1627/masuk
curl: (35) error:0A00010B:SSL routines::wrong version number (HTTP-only endpoint)
```

F-02: Permissive Content Security Policy with unsafe-inline Directives

English	Bahasa Indonesia
Risk Rating: MEDIUM | **CWE:** CWE-1021 / CWE-79 | **Status:** Verified Config Flaw	**Risk Rating:** MEDIUM | **CWE:** CWE-1021 / CWE-79 | **Status:** Kelemahan Konfigurasi Terverifikasi
Impact: Both endpoints emit a Content Security Policy containing script-src 'unsafe-inline' and style-src 'unsafe-inline'. This disables modern browser protection against Cross-Site Scripting (XSS), allowing injected inline scripts to execute if an unsanitized reflection vector exists.	**Dampak:** Kedua target menyajikan header CSP yang memuat script-src 'unsafe-inline' dan style-src 'unsafe-inline'. Hal ini meniadakan perlindungan utama browser terhadap Cross-Site Scripting (XSS), sehingga script berbahaya dapat dieksekusi bila ditemukan titik injeksi input.
Detailed Narrative: Header audits confirmed permissive CSP settings. Reflected XSS probing was not completed due to single-pass iteration limits. The issue is classified as a verified configuration flaw rather than a demonstrated exploit.	**Deskripsi Rinci:** Pemeriksaan header membuktikan CSP permisif. Pengujian reflected XSS terhenti oleh batas iterasi satu putaran. Isu ini diklasifikasikan sebagai kelemahan konfigurasi nyata, bukan eksploitasi terbukti.
Recommended Remediation: Remove 'unsafe-inline', implement cryptographic nonces ('nonce-...'), and perform authenticated XSS audit.	**Rekomendasi Perbaikan:** Hapus 'unsafe-inline', gunakan cryptographic nonce ('nonce-...'), dan lakukan uji penetrasi terotorisasi lanjutan.

```
Content-Security-Policy: default-src 'none'; script-src 'unsafe-inline'; style-src 'unsafe-inline'; frame-ancestors 'none'
```

F-03: Redundant and Conflicting Security Headers via Reverse Proxy Layering

English	Bahasa Indonesia
Risk Rating: LOW | **CWE:** CWE-16 | **Status:** Configuration Inconsistency Confirmed	**Risk Rating:** LOW | **CWE:** CWE-16 | **Status:** Inkonsistensi Konfigurasi Terverifikasi
Impact: HTTPS responses emit duplicated and contradictory security headers: X-Frame-Options: DENY and SAMEORIGIN simultaneously, duplicate Referrer-Policy, and duplicated X-Content-Type-Options. Browsers may interpret conflicting headers unpredictably, potentially disabling clickjacking defenses.	**Dampak:** Respons HTTPS menyajikan header keamanan ganda yang saling bertentangan: X-Frame-Options: DENY dan SAMEORIGIN secara bersamaan, duplikasi Referrer-Policy, serta X-Content-Type-Options ganda. Browser dapat memproses konflik secara acak dan berpotensi membatalkan proteksi anti-clickjacking.
Remediation: Designate the edge Nginx reverse proxy as the authoritative header injector; suppress backend duplicates.	**Rekomendasi Perbaikan:** Tetapkan edge reverse proxy Nginx sebagai pengendali header tunggal; bersihkan header duplikat dari backend.

6. ADDITIONAL SECURITY OBSERVATIONS & TELEMETRY

English	Bahasa Indonesia
O-01 (Server Banner Disclosure): The public endpoint exposes Server: nginx while the internal endpoint exposes Server: RBFR. Although specific build versions are not displayed, disclosing software names aids attacker fingerprinting. **O-02 (Metadata Routing & TLS Errors):** /robots.txt and /.well-known/security.txt trigger HTTP 303 redirects to /masuk on port 1627. Strict TLS validation on hostname produced curl (60) due to local trust bundle limits.	**O-01 (Pengungkapan Banner Layanan):** Endpoint publik mengekspos Server: nginx sedangkan endpoint internal mengekspos Server: RBFR. Kendati versi build spesifik tidak terlihat, informasi ini mempermudah pemetaan teknologi target. **O-02 (Routing Metadata & Error TLS):** Path /robots.txt dan /.well-known/security.txt dialihkan via HTTP 303 ke /masuk pada port 1627. Validasi TLS strict pada hostname memunculkan error curl (60) akibat trust store lokal.

7. VERIFIED CONTROLS & NEGATIVE TEST RESULTS / KONTROL TERVERIFIKASI

Security Parameter & Control (English)	Hasil Verifikasi Lapangan (Bahasa Indonesia)
Host Network Attack Surface: Nmap scan on host 10.110.1.9 across top-1000 ports plus port 1627 confirmed that only TCP/1627 is open.	**Permukaan Serangan Host:** Pemindaian Nmap pada 10.110.1.9 mengonfirmasi hanya port 1627 yang terbuka. Tidak ada port manajemen (SSH, RDP, DB) yang terekspos.
HTTP-to-HTTPS Redirection: Hostname rekapbudget-estate.first-resources.com enforces HTTP 301 Moved Permanently redirect to HTTPS.	**Pengalihan HTTP ke HTTPS:** Hostname publik secara benar menerapkan pengalihan 301 dari HTTP biasa ke koneksi aman HTTPS.
HSTS Implementation: Strict-Transport-Security active with max-age=15552000 and includeSubDomains.	**Penerapan HSTS:** Header HSTS aktif pada HTTPS dengan durasi 180 hari (15552000 detik) mencakup seluruh subdomain.
TLS Certificate Legitimacy: Valid commercial Sectigo wildcard certificate (*.first-resources.com) active through January 2027.	**Validitas Sertifikat TLS:** Menggunakan sertifikat resmi Sectigo wildcard valid dengan masa aktif hingga 13 Januari 2027.
Authentication Rejection: Dummy POST probe to /masuk returned HTTP 401 Unauthorized without error bypass.	**Penolakan Autentikasi Dummy:** Percobaan kredensial palsu pada /masuk menghasilkan respons 401 Unauthorized yang valid.

8. TESTING LIMITATIONS & UNTESTED BOUNDARIES / BATASAN PENGUJIAN

English	Bahasa Indonesia
• **Linear Single-Pass Constraint:** Conducted under strict anti-loop execution guidelines (max 1 probe per tool, no retries, no deep recursion). • **Session Cookie Flags Unverified:** No Set-Cookie header observed on unauthenticated GET requests. Post-auth flags (Secure, HttpOnly, SameSite) could not be verified. • **Input Reflection & XSS Inconclusive:** Reflection probing was suspended upon reaching subtask iteration limits; no malicious payloads were transmitted. • **Rate Limiting Inconclusive:** A single dummy attempt gave HTTP 401 without 429/Retry-After. Progressive throttling cannot be conclusively confirmed from one request. • **Zero Destructive Impact:** No brute-forcing, password spraying, SQL injection fuzzing, or DoS testing was conducted.	• **Batasan Alur Linear 1 Putaran:** Dilakukan dengan pedoman bebas macet ketat (maksimal 1 percobaan per tool, tanpa retry, tanpa crawling dalam). • **Flag Cookie Sesi Belum Teruji:** Header Set-Cookie tidak muncul pada GET awal. Flag pasca-login (Secure, HttpOnly, SameSite) belum dapat dinilai. • **Uji Reflected XSS Belum Tuntas:** Probe parameter reflection terhenti oleh limit iterasi; tidak ada payload eksploitatif yang dievaluasi. • **Rate Limiting Belum Konklusif:** Satu percobaan dummy menghasilkan HTTP 401 tanpa header 429. Mekanisme lock-out membutuhkan uji multi-request terotorisasi. • **Bebas Dampak Destruktif:** Tidak dilakukan brute-force, password spraying, injeksi SQL merusak, atau uji kelumpuhan sistem (DoS).

9. ACTIONABLE REMEDIATION ROADMAP / PANDUAN PERBAIKAN

English	Bahasa Indonesia
1. Decommission or Proxy Plaintext HTTP Port 1627 — Priority: **HIGH** Rebind internal BIMS service to 127.0.0.1:1627 and enforce access through an authoritative HTTPS reverse proxy. Enforce host firewall rules blocking cross-VLAN traffic and rotate credentials used across internal tests.	**1. Tutup atau Alihkan Layanan HTTP Plaintext Port 1627** — Prioritas: **HIGH** Ubah binding BIMS internal ke 127.0.0.1:1627 dan wajibkan seluruh akses melalui reverse proxy HTTPS. Terapkan firewall host untuk memblokir akses langsung antar-VLAN serta lakukan rotasi kredensial pengguna internal.
2. Normalize Security Headers at Edge Reverse Proxy — Priority: **MEDIUM** Consolidate security headers in Nginx configuration. Remove duplicates and enforce single authoritative directives (X-Frame-Options: DENY, Referrer-Policy: strict-origin-when-cross-origin). Use proxy_hide_header.	**2. Normalisasi Header Keamanan pada Reverse Proxy** — Prioritas: **MEDIUM** Satukan konfigurasi header pada Nginx. Hapus nilai duplikat dan tetapkan satu kebijakan tegas (X-Frame-Options: DENY, Referrer-Policy: strict-origin-when-cross-origin). Gunakan proxy_hide_header.
3. Harden Content Security Policy (CSP) — Priority: **MEDIUM** Remove 'unsafe-inline' from script-src and style-src. Adopt cryptographic nonces or SHA-256 hashes.	**3. Perketat Content Security Policy (CSP)** — Prioritas: **MEDIUM** Hapus 'unsafe-inline' pada direktif script-src dan style-src. Terapkan mekanisme nonce atau hash SHA-256.
4. Enforce Session Cookie Flags Post-Login — Priority: **LOW / MEDIUM** Ensure all cookies issued upon successful authentication include Secure; HttpOnly; SameSite=Lax.	**4. Terapkan Flag Cookie Sesi Pasca-Login** — Prioritas: **LOW / MEDIUM** Pastikan cookie sesi yang diterbitkan setelah login memuat atribut Secure; HttpOnly; SameSite=Lax.

10. CONCLUSION / KESIMPULAN

English	Bahasa Indonesia
Within the executed linear single-pass scope, the **BIMS / Rekapitulasi Budget FR - Estate** application demonstrates effective perimeter security controls on its public HTTPS interface (valid wildcard TLS, HSTS, and 401 auth rejection). However, exposing an unencrypted HTTP/1.0 login interface directly on internal IP 10.110.1.9:1627 introduces a critical transport flaw (**F-01: High**) that bypasses transport encryption and leaves authentication credentials vulnerable to internal network interception. Remediation must prioritize closing or proxying port 1627 behind HTTPS, followed by normalizing duplicate security headers and hardening the Content Security Policy to achieve comprehensive enterprise production posture.	Dalam cakupan pengujian linear satu putaran yang dilakukan, sistem **BIMS / Rekapitulasi Budget FR - Estate** menunjukkan pertahanan perimeter yang efektif pada interface HTTPS publiknya (sertifikat wildcard TLS valid, HSTS, dan penolakan 401 auth). Namun, ketersediaan antarmuka login HTTP/1.0 tanpa enkripsi langsung pada IP internal 10.110.1.9:1627 memunculkan kerentanan transport kritis (**F-01: High**) yang mengabaikan enkripsi lalu lintas data dan membuka celah penyadapan kredensial. Remediasi harus memprioritaskan penutupan atau pengalihan port 1627 ke jalur HTTPS, disusul dengan normalisasi header keamanan ganda serta pengetatan Content Security Policy demi mencapai postur keamanan produksi enterprise yang tangguh.

Report Prepared By: Cyber Security Assessment Division Lentera Teknologi	**Classification:** CONFIDENTIAL — INTERNAL ONLY Zero Defect Assessment Standard	**Document Verification:** ECC Gate 1-5 Compliant Date: 18 Oktober 2026